

ACTIVITY PACK

Activity 4: Readme

Activity 4 - Evidence-Based Rogue Agent Incident Review

Course	AI Security for Autonomous AI Agents
Course code	TGS-2025060473
Version	3.0 20 August 2026

Tertiary Infotech Pte Ltd | UEN 20120096W

Readme

Activity 4 - Evidence-Based Rogue Agent Incident Review

Course: AI Security for Autonomous AI Agents **Course Code:** TGS-2025060473 | **TSC:** ICT-INT-0052-1.1 **Block:** Day 2 - Autonomous Agent Security

At a glance

Duration	60 minutes
Format	Small groups of 3 - 4, plenary debrief
Type	Evidence-based review: verified cases plus one reported security-research campaign
Learning Outcome	LO3
K/A statements assessed	K5

Purpose

Learners review EchoLeak, the Amazon Q Developer extension supply-chain event, the Replit application-database incident, and the reported ClawHavoc malicious-skill campaign. They distinguish evidence status, reconstruct source-to-sink chains, and identify the earliest deterministic control that could break each chain.

Files in this folder

File	Audience	Use
SCENARIO.md	Learner	The case study narrative, artefacts and data
DISCUSSION-QUESTIONS.md	Learner	The five questions to work through in groups
SKILL-PLUGIN-RISK-REVIEW.md	Learner	Supply-chain review exercise for skills, plugins and MCP servers
SECURITY-CHECKLIST.md	Learner	Autonomous-agent containment checklist
Activity-4-*.pdf	Learner	Printable full learner pack including supply-chain review and checklist

How to run it

- Set up (5 min).** Form groups of 3 - 4. Issue SCENARIO.md and DISCUSSION-QUESTIONS.md. Trainer debrief notes are supplied separately and are not stored in the learner-facing Activities folder.
- Group work (45 minutes).** Groups work the five questions in order. Circulate; the questions are designed to be argued, not looked up.
- Presentation (5 minutes).** Each group presents its answer to one nominated question.
- Debrief (5 minutes).** Use the separate trainer notes to draw out the teaching points and correct recurring misconceptions.

Learner workflow

- Create an evidence card for EchoLeak, Amazon Q, Replit and ClawHavoc: source, publication date, evidence class and exact supported claim.
- For every case, separate normal capability, vulnerability or control failure, and observed or possible impact.
- Map untrusted source, interpretation mechanism, identity or permission, privileged sink and effect.
- Record what the source does **not** establish; preserve the Amazon Q, Replit and ClawHavoc cautions.
- Complete SKILL-PLUGIN-RISK-REVIEW.md for one skill, plugin or MCP server, including provenance, version, update channel, requested capabilities and bundled code.

6. Choose one preventive and one detective or recovery control at the earliest feasible chain point.
7. Define any required approval screen: exact action, target, data, scope, destination, reversibility and evidence shown.
8. Present the reconstruction without converting a vulnerability, demonstration or reported campaign into an unsupported production-breach claim.

Required evidence

- Four evidence cards, each with a dated source and CASE-V or CASE-R label.
- Four source-to-sink chains with supported and unsupported claims separated.
- One skill/plugin/MCP supply-chain review with an allow, conditional-allow or deny decision.
- Preventive plus detective or recovery controls, with owners, test evidence and residual risk.

Acceptance criteria

The submission passes when all four evidence classes and source cautions are preserved; Amazon Q is stated as not executed, Replit as restored with no data loss, and ClawHavoc figures retain their dated methodology limits; and the supply-chain review ends in an explicit gate decision.

The slide deck remains concept-led. These learner procedures are also reproduced in the Learner Guide.

Alignment

Every question in DISCUSSION-QUESTIONS.md is tagged with the K or A statement it evidences. This activity contributes to **LO3** and is assessed through the Written Assessment (SAQ).

This material belongs to Tertiary Infotech Pte Ltd (UEN: 20120096W). All Rights Reserved.